

Управленческий отчёт по инциденту информационной безопасности

Резюме

15 апреля 2025 года в компании Demo Lab была зафиксирована целевая кибератака. Злоумышленник, используя фишинговое письмо с вредоносным вложением, получил доступ к рабочей станции сотрудника финансового отдела. В результате атаки были скомпрометированы три ключевые системы: рабочая станция, контроллер домена и файловый сервер. Злоумышленник похитил конфиденциальные данные, включая финансовые отчёты, кадровую информацию и стратегические документы. Общий объём украденных данных составил около 39МБ или 5 конфиденциальных файлов. Атака была проведена с использованием профессиональных инструментов (DarkGate, Mythic Frejya), что указывает на высокий уровень подготовки злоумышленника. На данный момент активная фаза атаки остановлена, однако для предотвращения повторных инцидентов требуется внедрение ряда мер

Бизнес-воздействие

1. **Компрометация контроллера домена** - злоумышленник получил полный контроль над основным элементом IT-инфраструктуры компании. Это означает, что он мог получить доступ к любым системам, изменять учётные записи и отключать средства защиты. Возможные последствия: возможное нарушение работы всех сервисов, зависящих от Active Directory.
2. **Утечка конфиденциальных данных** - похищены финансовые документы (бюджет), кадровая информация (личные данные сотрудников), стратегические планы, учётные данные администраторов. Это может привести к:
 - Финансовым потерям (в случае использования украденного бюджета или налоговой отчётности).
 - Репутационному ущербу (утечка персональных данных сотрудников).
 - Риску компрометации партнёров (учётные данные администраторов могут быть использованы для атак на другие компании).
3. **Нарушение доверия** - инцидент подрывает доверие сотрудников и партнёров к защищённости компании, что может повлиять на деловые отношения и контракты.

Ключевые выводы

1. Недостаточная защита от фишинга. Почтовый шлюз не блокировал вложения с исполняемыми файлами. Сотрудники не имеют достаточных навыков распознавания фишинговых писем.

2. Отсутствие многофакторной аутентификации (MFA) для административных учётных записей. Это позволило злоумышленнику использовать пароль для входа на контроллер домена.
3. Отсутствие сегментации сети. Компрометация одной рабочей станции позволила злоумышленнику получить доступ к контроллеру домена и файловому серверу.
4. Слабое обнаружение атак. Вредоносное ПО (DarkGate и Mythic Frejya) работало незаметно в течение длительного времени без детектирования.

Рекомендации для руководства

Немедленные действия (0–30 дней)

1. Внедрить многофакторную аутентификацию (MFA) для всех административных учётных записей. Это предотвратит использование украденных паролей даже в случае компрометации.
2. Настроить фильтрацию вложений в почтовом шлюзе. Запретить исполняемые файлы (.exe, .scr, .msi) в почтовых вложениях, за исключением согласованных исключений. Внедрить системы такие, как Sandbox.
3. Провести смену всех паролей администраторов и других учётных записей, которые могли быть скомпрометированы (включая пользователя user7).
4. Заблокировать на сетевом уровне выявленные вредоносные IP-адреса и домены (список предоставлен в техническом отчёте).

Среднесрочные меры (1–3 месяца)

1. Внедрить сегментацию сети. Разделить сеть на сегменты с ограничением доступа между рабочими станциями и серверами (особенно контроллером домена).
2. Ужесточить политику паролей. Устанавливать сложные пароли и регулярную смену для всех учётных записей.
3. Развернуть EDR-системы на всех серверах и рабочих станциях (если ещё не развёрнуто) с интеграцией в SIEM для оперативного реагирования.
4. Провести обучение сотрудников по распознаванию фишинговых писем (с акцентом на вложения и подозрительные ссылки).

Долгосрочная стратегия (3–12 месяцев)

1. Создать и внедрить стандартные процедуры реагирования на инциденты (плейбуки) для быстрого и системного обнаружения и устранения атак.
2. Настроить мониторинг и алертинг в SIEM на модификацию реестра, запуск скриптовых интерпретаторов, RDP-подключения с нестандартных IP, очистку логов и другие подозрительные действия.
3. Проводить регулярные учения для SOC и IT-команды по отработке сценариев атак, чтобы сократить время обнаружения и реагирования.
4. Внедрить систему анализа и обогащения инцидентов (Threat Intelligence) для автоматического выявления известных вредоносных адресов и хэшей.

Заключение

Инцидент показал, что существующая система защиты компании не является достаточной для отражения целенаправленных атак. Компрометация контроллера домена и утечка конфиденциальных данных требуют немедленных действий. Реализация предложенных мер (MFA, фильтрация вложений, сегментация сети, усиление мониторинга и обучение сотрудников) значительно повысит защищённость компании и снизит риски повторения подобных инцидентов. Рекомендуется утвердить план мероприятий с указанием ответственных лиц и установленных сроков, а также выделить необходимый бюджет для внедрения недостающих систем защиты.